

README — KIT GQM + PRAGMATIC · LINDDUN/LIINE4DU 2025–2026

Guía de Inicio Rápido · Descripción Completa del Kit · Referencias

Versión 1.0 · Abril 2026 · España · Español

"Un sistema de medición que no se entiende no se usa. Uno que se usa pero mide mal, daña. Este README existe para que el Kit GQM+PRAGMATIC se entienda, se use bien y, de paso, mejore la privacidad de las organizaciones que lo adopten."

¿QUÉ ES ESTE KIT Y POR QUÉ ES DIFERENTE?

El **Kit GQM+PRAGMATIC para LINDDUN/LIINE4DU** es el primer instrumento de diagnóstico de madurez en privacidad para el mercado español que integra dos metodologías de clase mundial:

- **GQM** (Goal–Question–Metric, Basili & Weiss, 1984): garantiza que cada métrica existe porque responde a una pregunta, que a su vez sirve a un objetivo estratégico. Proporciona trazabilidad completa desde los objetivos regulatorios nacionales (RGPD, AI Act, NIS2, ENS) hasta los datos técnicos más granulares.
- **PRAGMATIC** (Brotby & Hinson, 2013): evalúa la calidad de cada métrica según nueve criterios (Predictivo, Relevante, Accionable, Genuino, Meaningful, Accurate, Timely, Independiente, Cheap). Solo las métricas que superan el umbral de calidad se incluyen en el cuadro de mando. El resultado: métricas que sirven para decidir, no solo para reportar.

GQM (Goal–Question–Metric, Basili & Weiss, 1984): garantiza que cada métrica existe porque responde a una pregunta, que a su vez sirve a un objetivo estratégico. Proporciona trazabilidad completa desde los objetivos regulatorios nacionales (RGPD, AI Act, NIS2, ENS) hasta los datos técnicos más granulares.

PRAGMATIC (Brotby & Hinson, 2013): evalúa la calidad de cada métrica según nueve criterios (Predictivo, Relevante, Accionable, Genuino, Meaningful, Accurate, Timely, Independiente, Cheap). Solo las métricas que superan el umbral de calidad se incluyen en el cuadro de mando. El resultado: métricas que sirven para decidir, no solo para reportar.

La diferencia respecto a checklists y auditorías convencionales es sencilla: **este kit mide lo que importa porque primero define qué importa y luego verifica que la medición es fiable.**

CONTENIDO DEL KIT — 7 ARCHIVOS

 **(a) marco-GQM-PRAGMATIC-LINDDUN.md**

Marco Integrativo GQM + PRAGMATIC

El documento fundacional del kit. Contiene:

- Fundamentos teóricos completos de QQM y PRAGMATIC
- Jerarquía de objetivos nacionales (OBJ-ES-1 a OBJ-ES-5) y tácticos (OBJ-L a OBJ-EX)
- Catálogo completo de 21 métricas cuantitativas organizadas por indicador LINDDUN
- Fórmulas matemáticas para cada métrica (k-anonimato, epsilon DP, DIR, ICAV, TTDL, etc.)
- Umbrales por métrica con justificación normativa
- Cuadro de mando integrado (Privacy KPI Dashboard) con tabla resumen

Leer primero: es la base teórica que justifica todo lo demás.

(b) matriz-PRAGMATIC-LINDDUN.md

Matriz de Evaluación PRAGMATIC Completa

El tribunal de calidad de las métricas. Contiene:

- Evaluación de cada métrica según los 9 criterios PRAGMATIC (0-10)
- Justificación argumentada de cada puntuación
- Tabla resumen global con ranking PRAGMATIC (NC-M3: 9.00 → mejor; IMD DD-M5: 6.89 → revisar)
- Análisis de brechas: criterios más débiles del catálogo y acciones de mejora
- Umbrales de calidad: ≥ 8.0 (Excelente), ≥ 6.5 (Buena), < 5.0 (Revisar)

Para el DPO y el CISO: permite seleccionar qué métricas incluir en el cuadro de mando según el balance coste/calidad específico de su organización.

(c) narrativa-GQM-PRAGMATIC-LINDDUN.md

Narrativa Explicativa

El "por qué" del kit, en 7 capítulos. Contiene:

- Por qué el cumplimiento declarativo no es suficiente
- El método GQM: el arte de hacerse las preguntas correctas
- PRAGMATIC: el tribunal de calidad de las métricas
- La integración GQM+PRAGMATIC: mayor que la suma de sus partes
- El caso español: entre el mapa y el territorio
- El AI Act y el nuevo horizonte de las métricas de IA
- Epílogo: la privacidad como práctica, no como performance

Distribuir a todos los participantes antes de la sesión de diagnóstico. Especialmente útil para convencer a directivos escépticos de la utilidad del enfoque.

(d) mapeo-normativo-GQM-LINDDUN.md

Mapeo Detallado: Métricas → Requisitos Normativos

La "biblia jurídica" del kit. Contiene:

- Tabla maestra de trazabilidad: 21 métricas $\times$ 9 columnas normativas (RGPD, AI Act, NIS2, ENS, LIINE4DU, ISO, NIST)

- Indicación del nivel de riesgo regulatorio por métrica (● Crítico → ● Bajo)
- Top 10 métricas por sanción potencial (NC-M5: hasta 35 M€; DD-M2: caso TikTok 530 M€)
- Tabla de cobertura normativa por indicador LINDDUN
- Artículos específicos aplicables para cada tipo de tratamiento

Para el equipo legal y el DPO: proporciona la justificación jurídica de cada decisión de medición y facilita la preparación de EIPDs y la respuesta a inspecciones de la AEPD.

(e) [plantilla-IGM-ROI-GQM-LINDDUN.md](#)

Especificación de la Plantilla Excel IGM + ROI GQM

El manual de implementación de la calculadora avanzada. Contiene:

- Estructura de 10 hojas del libro Excel:
CONFIG_GQM · METRICAS_GQM · PRAGMATIC_EVAL · IGM_CALCULO · RADAR_GQM · ROI_PRIVACIDAD ·
PLAN_MEJORA_GQM · BENCHMARKING · TRAZABILIDAD · AUDITORIA
- Fórmula IGM estándar y fórmula IGM **ajustada por PRAGMATIC** (novedad respecto al kit anterior)
- Función de normalización de métricas heterogéneas para el cálculo IGM
- Fórmula de ROI GQM ajustado (incluye coste de medición en el denominador)
- Fórmula de Puntuación de Prioridad (PP) para el Plan de Mejora
- Tabla de pesos por indicador con justificación
- Todas las fórmulas Excel listas para copiar e implementar

Para el área de Sistemas/TI: implementar la plantilla en Excel 365, Google Sheets o LibreOffice Calc según las instrucciones paso a paso del documento.

(f) [reporte-ejecutivo-GQM-LINDDUN.md](#)

Especificación del Reporte Ejecutivo en PowerPoint

El manual de presentación para la Alta Dirección. Contiene:

- Paleta de colores extendida con identificadores visuales por indicador LINDDUN
- 20 diapositivas + 5 apéndice, especificadas en detalle:
 - Diap. 1-2: Portada y metodología
 - Diap. 3-5: Resumen ejecutivo, contexto, arquitectura GQM
 - Diap. 6-7: Radar triple GQM+PRAGMATIC y tabla de puntuaciones
 - Diap. 8-9: Top 5 mejores y peores métricas
 - Diap. 10-13: Análisis por indicador LINDDUN (2 por diapositiva)
 - Diap. 14: Tabla de calor de calidad PRAGMATIC
 - Diap. 15-16: ROI "iceberg" y proyección 3 años
 - Diap. 17-18: Plan de acción y benchmarking
 - Diap. 19-20: Diferencial GQM y conclusiones
 - Apéndice A1-A5: Glosario, catálogo, trazabilidad, normativa, metodología IGM

Novedad respecto al kit anterior: las diapositivas 14 (tabla de calor PRAGMATIC) y 19 (contraste sin/con GQM) son exclusivas de esta versión y son frecuentemente las que más impacto generan en los Consejos de Administración.

 **(g) README-GQM-LINDDUN.md**

Este documento

La guía de inicio rápido del kit completo.

FLUJO DE TRABAJO RECOMENDADO

FASE 0 – FORMACIÓN (1-2 semanas antes)

- └ Todo el equipo lee narrativa-GQM-PRAGMATIC-LINDDUN.md (30 min)
- └ DPO y CISO estudian marco-GQM-PRAGMATIC-LINDDUN.md (2h)
- └ DPO revisa matriz-PRAGMATIC-LINDDUN.md y selecciona métricas activas (1h)
- └ Sistemas implementa plantilla-IGM-ROI-GQM-LINDDUN.md en Excel (1-2 días)

FASE 1 – RECOLECCIÓN DE DATOS (1-4 semanas)

- └ Identificar fuente de datos para cada métrica activa
- └ Recopilar valores medidos (SIEM, herramientas GRC, registros del DPO...)
- └ Introducir valores en Hoja 2 (METRICAS_GQM) del Excel
- └ Documentar evidencias en Hoja 10 (AUDITORIA) del Excel

FASE 2 – ANÁLISIS (2-3 días)

- └ Verificar cálculo del IGM (Hojas 4 y 5)
- └ Revisar Plan de Mejora generado automáticamente (Hoja 7)
- └ Calcular ROI ajustado PRAGMATIC (Hoja 6)
- └ Contrastar con mapeo-normativo-GQM-LINDDUN.md los ítems ●

FASE 3 – COMUNICACIÓN (3-5 días)

- └ Elaborar presentación siguiendo reporte-ejecutivo-GQM-LINDDUN.md
- └ Presentar al Comité de Dirección o equivalente
- └ Obtener aprobación del Plan de Mejora con presupuesto asignado
- └ Comunicar compromisos a todos los responsables de acción

FASE 4 – IMPLEMENTACIÓN Y SEGUIMIENTO (12 meses)

- └ Ejecutar acciones del Plan de Mejora por orden de PP (Puntuación de Prioridad)
- └ Actualizar métricas según la frecuencia de cada una (mensual/trimestral/anual)
- └ Reportar avance trimestral al Comité de Dirección
- └ Repetir el diagnóstico completo al año siguiente

MÉTRICAS DEL KIT POR FRECUENCIA DE ACTUALIZACIÓN

Frecuencia	Métricas	Nota
Continua (tiempo real)	NC-M3 (brechas ≤72h), NC-M4 (TMNB), L-M4 (TTDL)	Requieren SIEM o sistema de alerta
Mensual	NR-M1 (completitud logs), U-M2 (ARCO+), DD-M3 (prompts IA)	Extraer de sistemas de gestión
Trimestral	U-M3 (consentimientos válidos), D-M5 (empleados informados)	Auditoría de muestra
Semestral	L-M3 (ICAV), DD-M1 (DPAs), NC-M5 (IPAA)	Revisión de controles
Anual	L-M1 (DFDs), U-M1 (ILPP), D-M1 (IPV), EX-M1 (WCAG)	Ciclo de cumplimiento anual
Por evento	I-M4 (EIPD biométrica), L-M5 (EIPD ML), IN-M3 (DIR)	Al desplegar nuevo sistema

FÓRMULAS CLAVE — REFERENCIA RÁPIDA

IGM Estándar:

=SUMAPRODUCTO(Madurez_por_módulo; Peso_por_módulo)

IGM Ajustado PRAGMATIC:

=SUMAPRODUCTO(Madurez*Calidad; Pesos) / SUMAPRODUCTO(Pesos; Calidad)

Puntuación PRAGMATIC total:

=PROMEDIO(P; R; A; G; M; A_acc; T; I; C)

ROI GQM Ajustado:

=((CNC_Total - (IC_Total + CM_Total)) / (IC_Total + CM_Total)) * 100

Puntuación de Prioridad (Plan de Mejora):

=(Riesgo * 0.5) + (PRAGMATIC/10*4 * 0.3) + (Facilidad * 0.2)

K-anonimato:

k = MIN(tamaño de cada grupo de equivalencia)

Disparate Impact Ratio:

DIR = P(decisión_positiva | grupo_protegido) / P(decisión_positiva | grupo_referencia)

Índice Legibilidad Flesch (español adaptado – Fernández Huerta):

ILPP = 206.84 - 0.60*(sílabas/palabras) - 1.02*(palabras/frases)

REFERENCIAS BIBLIOGRÁFICAS Y NORMATIVAS

Metodología GQM:

- Basili, V.R. & Weiss, D.M. (1984). "A Methodology for Collecting Valid Software Engineering Data." IEEE Transactions on Software Engineering, 10(6), 728–738.
- Basili, V.R., Caldiera, G. & Rombach, H.D. (1994). "The Goal Question Metric Approach." Encyclopedia of Software Engineering. Wiley.

Metodología PRAGMATIC:

- Brothby, W.K. & Hinson, G. (2013). PRAGMATIC Security Metrics: Applying Metametrics to Information Security. CRC Press/Taylor & Francis. ISBN 978-1-4398-8153-8.

Marco LINDDUN:

- Wuyts, K. et al. (2015). "LINDDUN privacy threat modeling: a tutorial." Technical report CW 624, KU Leuven.
- Deng, M. et al. (2011). "A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements." Requirements Engineering, 16(1), 3–32.
- KU Leuven DistriNet (2025). "LINDDUN MAESTRO." Software & Systems Modeling, noviembre 2025.

Adaptación española:

- AEPD (2024). LIINE4DU 1.0: Adaptación española del marco LINDDUN. Octubre 2024.
- AEPD (2025). Notificaciones de Brechas de Datos Personales 2025. Enero 2026.

Normativa aplicable:

- RGPD: Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo
- LOPDGDD: Ley Orgánica 3/2018, de 5 de diciembre
- AI Act: Reglamento (UE) 2024/1689
- NIS2: Directiva (UE) 2022/2555 (transpuesta por Ley 11/2022)
- ENS: Real Decreto 311/2022
- eIDAS2: Reglamento (UE) 2024/1183
- NIST Privacy Framework 1.1 (2025)
- ISO/IEC 27001:2022 + 27701:2019 + 42001:2023

Privacidad diferencial:

- Dwork, C. & Roth, A. (2014). "The Algorithmic Foundations of Differential Privacy." Foundations and Trends in Theoretical Computer Science, 9(3–4), 211–407.

Equidad algorítmica (DIR):

- EEOC (1971). Uniform Guidelines on Employee Selection Procedures (regla del 80%).
- NIST AI RMF 1.0 (2023). Artificial Intelligence Risk Management Framework.

INICIO RÁPIDO (TL;DR — 5 minutos)

¿Tiene prisa? Siga estos 4 pasos:

1.
Convoque a su DPO, CISO y director legal con 48 horas de antelación. Envíeles la narrativa (archivo c) para que lleguen con contexto.
2.
Implemente la plantilla Excel (archivo e) antes de la reunión. No hace falta que esté perfecta: con las hojas CONFIG_GQM y METRICAS_GQM es suficiente para empezar.
3.
Mida las 3 métricas con mayor puntuación PRAGMATIC del catálogo:
4. NC-M3: ¿qué porcentaje de brechas se notifica en ≤72 horas?
5. DD-M1: ¿qué porcentaje de encargados tiene contrato DPA vigente?
6.
U-M3: ¿qué porcentaje de consentimientos cumple los 4 requisitos del Art. 7?
7.
Presente los resultados al Comité de Dirección con la plantilla PPT (archivo f). Foco en las diapositivas 3 (resumen ejecutivo), 15 (iceberg ROI) y 20 (compromisos).

Convoque a su DPO, CISO y director legal con 48 horas de antelación. Envíeles la narrativa (archivo c) para que lleguen con contexto.

Implemente la plantilla Excel (archivo e) antes de la reunión. No hace falta que esté perfecta: con las hojas CONFIG_GQM y METRICAS_GQM es suficiente para empezar.

Mida las 3 métricas con mayor puntuación PRAGMATIC del catálogo:

U-M3: ¿qué porcentaje de consentimientos cumple los 4 requisitos del Art. 7?

Presente los resultados al Comité de Dirección con la plantilla PPT (archivo f). Foco en las diapositivas 3 (resumen ejecutivo), 15 (iceberg ROI) y 20 (compromisos).

En 48 horas tendrá un diagnóstico parcial con las métricas de mayor valor regulatorio. El diagnóstico completo (21 métricas) se desarrolla a lo largo del primer mes.



Creative Commons Attribution 4.0 International (CC BY 4.0)

Uso, adaptación y distribución libre con atribución:

Kit GQM+PRAGMATIC para LINDDUN/LIINE4DU 2025–2026. Basado en el método GQM (Basili & Weiss, 1984), la metodología PRAGMATIC (Brotby & Hinson, 2013), el marco LINDDUN de KU Leuven/DistriNet y LIINE4DU 1.0 de la AEPD. Versión 1.0, Abril 2026.

"La privacidad no se declara. Se practica. Y la práctica, sin medición, es fe. Con medición, es gestión."

Kit GQM+PRAGMATIC · LINDDUN/LIINE4DU 2025–2026

Versión 1.0 — Abril 2026 | Licencia CC BY 4.0

Basado en LINDDUN © KU Leuven/DistriNet | LIINE4DU 1.0 © AEPD | PRAGMATIC © Brotby & Hinson